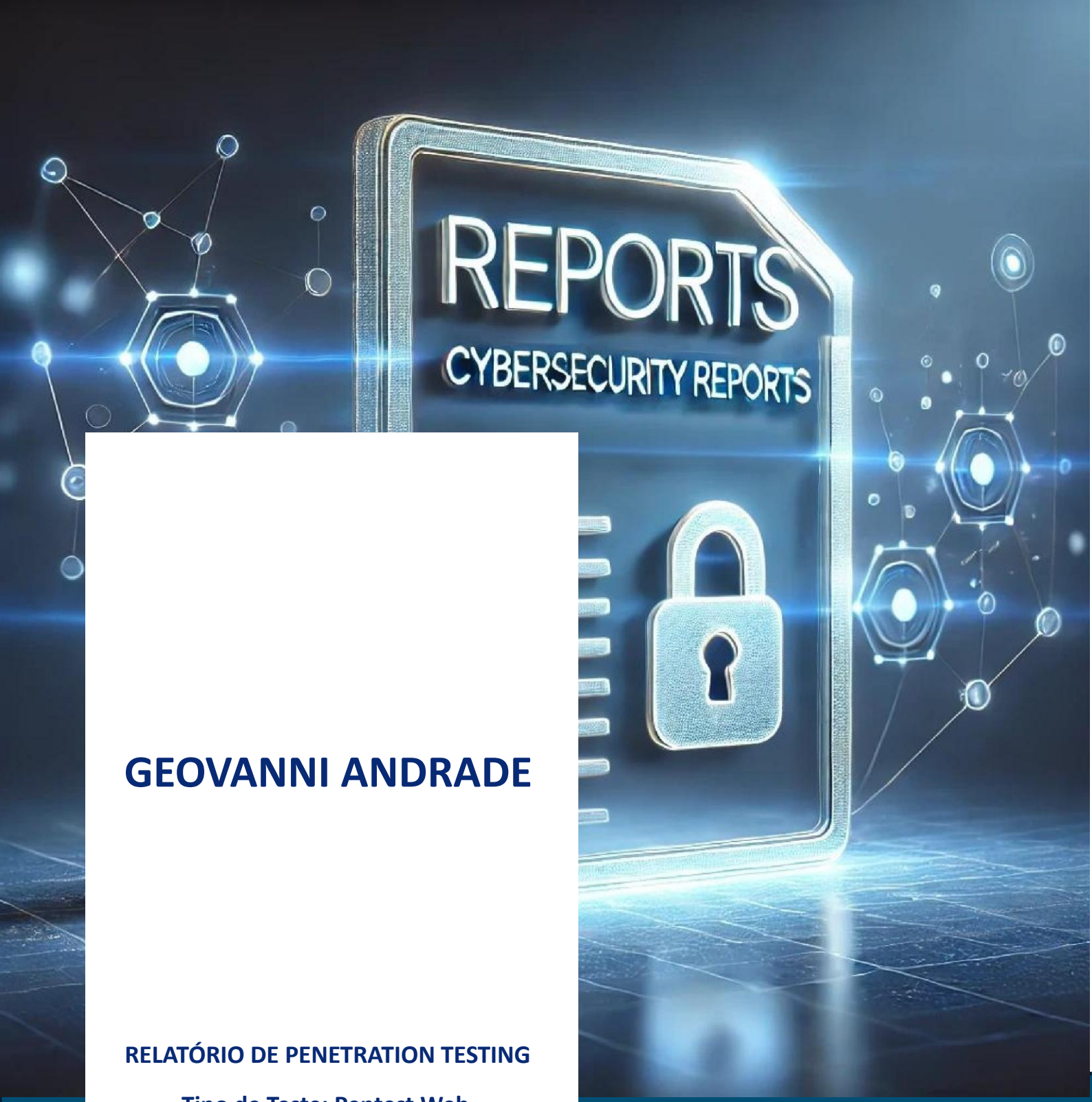


GEOVANNI ANDRADE

RELATÓRIO DE PENETRATION TESTING

Tipo de Teste: Pentest Web

Metodologia: Black Box

Data: 11/03/2026

FACULDADE IMPACTA

1. Sumário Executivo

Foi realizado um **teste de intrusão (Pentest Web)** em uma aplicação hospedada no servidor do laboratório com o objetivo de identificar vulnerabilidades de segurança e avaliar o impacto de possíveis explorações.

Durante a análise foram identificadas **duas vulnerabilidades principais**, que permitem a descoberta de funcionalidades internas da aplicação e a elevação indevida de privilégios.

As vulnerabilidades identificadas foram:

- Enumeração de diretórios e descoberta de arquivos sensíveis
- Falha de controle de autorização (Privilege Escalation)

A exploração dessas falhas permitiu obter acesso a funcionalidades administrativas da aplicação e extrair informações protegidas.

2. Escopo

Tipo de teste:

Pentest Web – Black Box

Alvo analisado:
http://192.168.0.9

Ferramentas utilizadas:

-> Nmap

-> Dirbuster

-> Burp Suite

-> CyberChef

-> Navegador Web

-> Kali Linux

3. Metodologia

O teste foi realizado seguindo as fases tradicionais de um teste de intrusão:

1- Reconhecimento
2- Enumeração
3- Identificação de vulnerabilidades
4- Exploração
5- Pós-exploração
6- Análise de impacto

Essa metodologia segue boas práticas amplamente utilizadas em testes de segurança, baseadas no **OWASP Testing Guide**.

4. Narrativa Técnica da Análise

Os testes começaram com a identificação de hosts ativos e serviços disponíveis na rede.

A partir dessa etapa foi possível identificar um servidor web ativo que hospeda a aplicação analisada.

Após a identificação do serviço HTTP, foi iniciada a fase de enumeração de diretórios para descobrir páginas ocultas e funcionalidades internas da aplicação.

Essa análise revelou endpoints sensíveis que posteriormente foram explorados.

5. Passo a Passo da Exploração

5.1 Reconhecimento da rede

Inicialmente foi realizado um scan de rede utilizando a ferramenta **Nmap** para identificar hosts ativos e serviços disponíveis.

Comando utilizado:

➔ nmap -sS -sV -Pn 192.168.0.0/24

O scan identificou o host **192.168.0.9** com a porta **80/tcp aberta**, executando o serviço **Apache httpd 2.4.46 (Debian)**.

Esse resultado confirmou a existência de uma aplicação web no alvo.

```
Nmap scan report for 192.168.0.9
Host is up (0.00063s latency).
Not shown: 999 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.46 ((Debian))
MAC Address: 08:00:27:ED:BD:C7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

5.2 Enumeração de diretórios

Após identificar o serviço HTTP, foi iniciada a enumeração de diretórios utilizando a ferramenta Dirbuster.

Foi utilizada a wordlist:

➔ directory-list-2.3-medium.txt

O objetivo dessa etapa foi descobrir arquivos e diretórios ocultos dentro da aplicação web.

Durante o processo foram identificados diversos caminhos relevantes:

/index.html

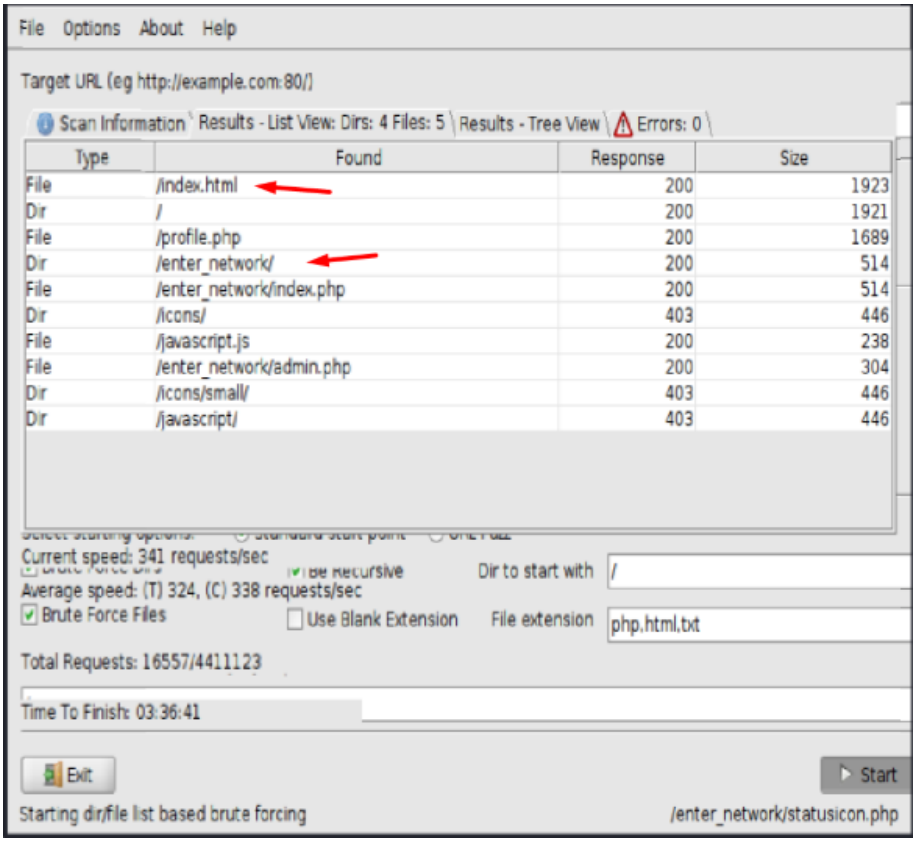
/profile.php

/exploit.html

/enter_network/

/enter_network/admin.php

Essas descobertas revelaram funcionalidades internas da aplicação que não estavam visíveis diretamente na interface principal.



5.3 Exploração do arquivo exploit.html

Após a enumeração, foi identificado o arquivo:

/exploit.html

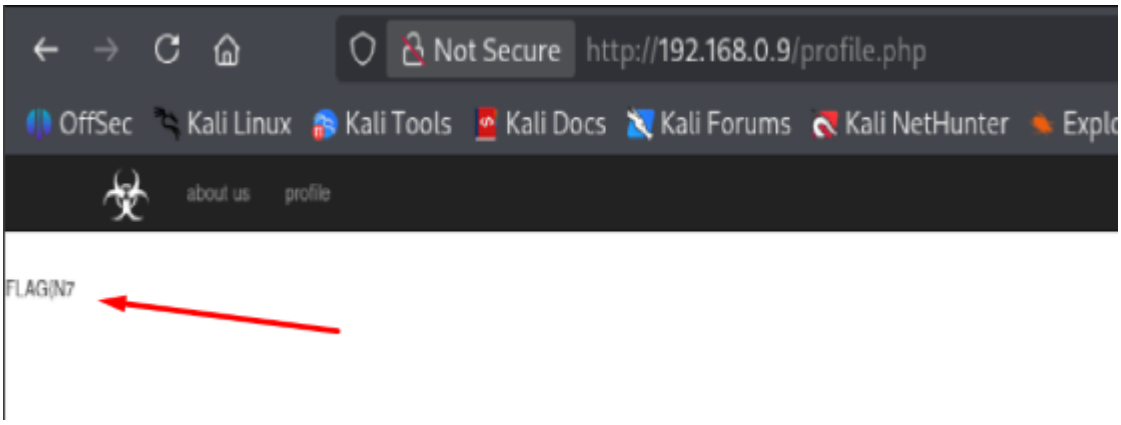
Ao acessar esse arquivo e analisar seu funcionamento, foi possível explorar um comportamento da aplicação que permitia interagir com funcionalidades internas.

Durante a análise foi necessário substituir referências de localhost pelo IP do servidor, permitindo que o exploit funcionasse corretamente.

Como resultado da exploração foi possível acessar a página:

/profile.php

Nessa página foi encontrada a primeira flag do laboratório.



5.4 Identificação da área administrativa

Durante a continuação da análise foi identificado o diretório:

/enter_network/

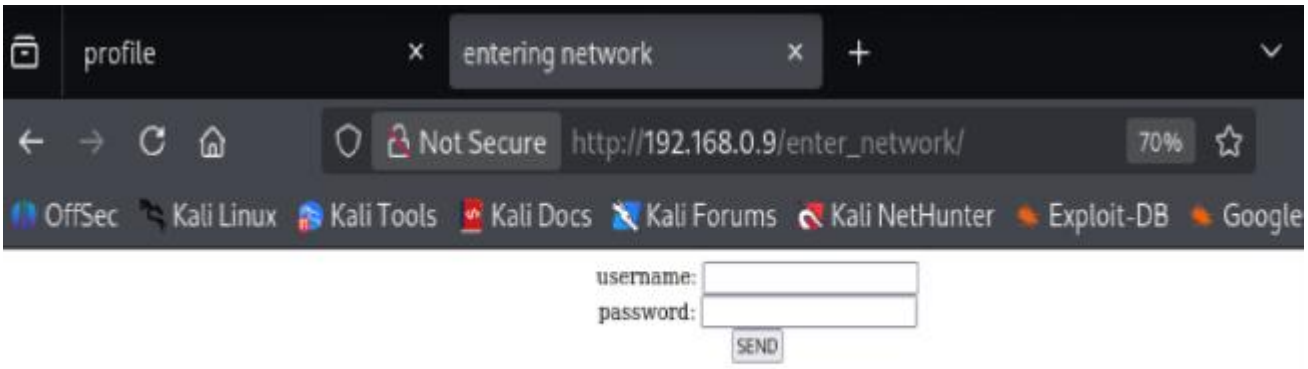
Essa página continha um formulário de autenticação com campos de usuário e senha.

Também foi identificado o endpoint:

/enter_network/admin.php

Ao tentar acessar diretamente essa página, o sistema indicava que a interface era restrita apenas para administradores.

Esse comportamento indicava a existência de um mecanismo de controle de acesso.



5.5 Interceptação de requisições com Burp Suite

Para entender como a autenticação funcionava, foi utilizado o **Burp Suite** como proxy interceptador.

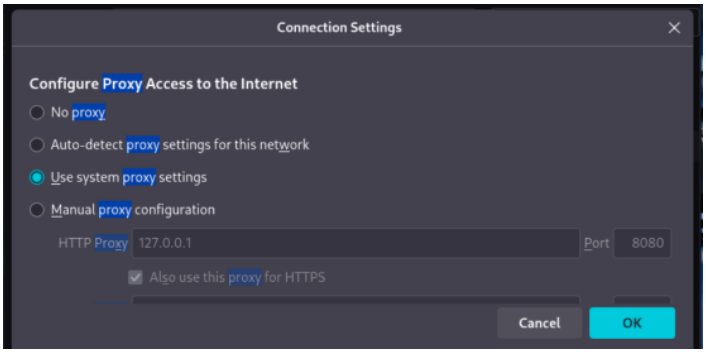
Procedimento realizado:

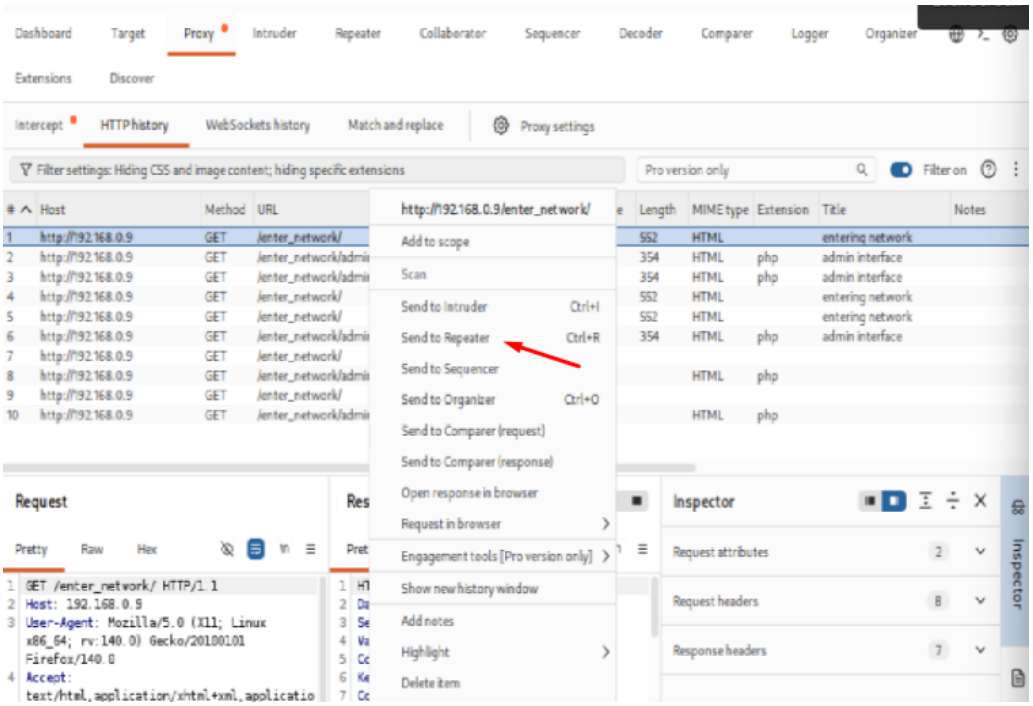
1. Iniciar o Burp Suite
2. Configurar o navegador para utilizar proxy 127.0.0.1:8080
3. Interceptar requisições HTTP da aplicação
4. Realizar login na aplicação

Credenciais utilizadas:

admin / admin

Com o proxy ativo foi possível capturar as requisições enviadas ao servidor.





5.6 Manipulação do token de Autorização

Ao analisar a requisição interceptada, foi identificado um valor codificado contendo informações sobre o perfil do usuário.

Esse valor foi extraído e analisado utilizando a ferramenta CyberChef, através do recurso ARGON2 Compare.

Foi identificado que o token armazenava o nível de acesso do usuário.

Valor original:

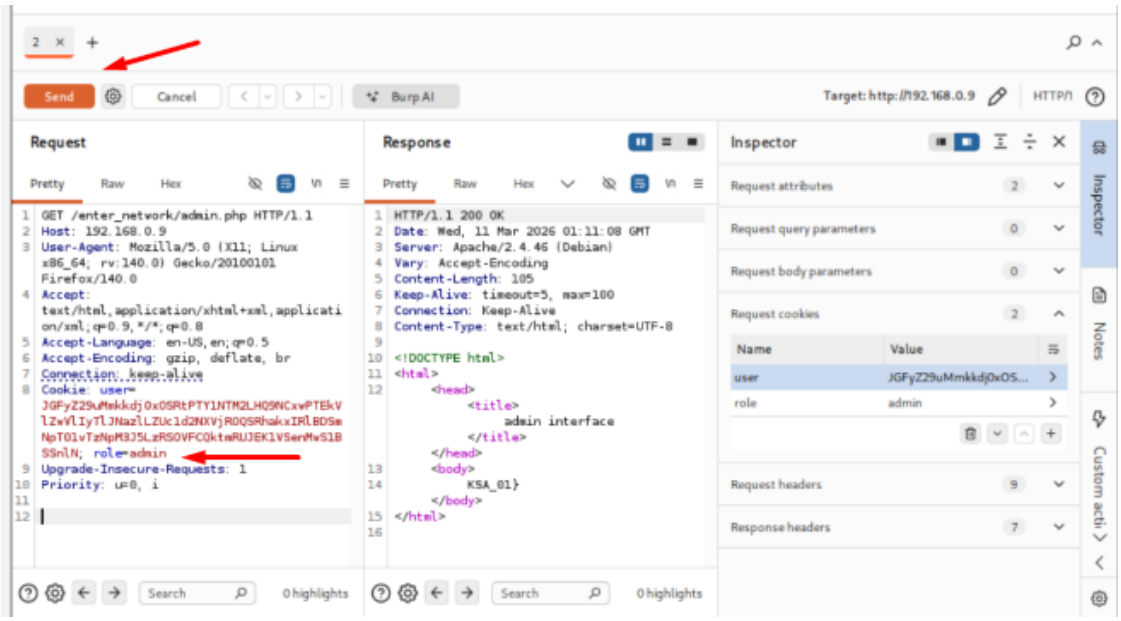
- role = recepter

Esse valor foi alterado manualmente para:

- role = admin

Após reenviar a requisição modificada para o servidor, o sistema passou a reconhecer o usuário como administrador.

Essa falha demonstra que o servidor confiava em dados manipuláveis enviados pelo cliente.



5.7 Obtenção da segunda flag

Após alterar o nível de acesso para administrador, foi possível acessar a interface administrativa da aplicação.

Durante a resposta da aplicação foi exibida a segunda flag do laboratório.

FLAG={N7 KSA_01}

Essa etapa confirma a exploração bem-sucedida da vulnerabilidade de controle de acesso.

6. Vulnerabilidades Identificadas

Vulnerabilidade 1

Enumeração de Diretórios

Descrição

A aplicação permite a descoberta de diretórios e arquivos internos através de ferramentas de brute force como Dirbuster.

Impacto:
- descoberta de funcionalidades ocultas
- identificação de áreas administrativas
- aumento da superfície de ataque

Classificação de risco

Médio

Vulnerabilidade 2

Falha de Controle de Autorização
A01:2021 – Broken Access Control

Descrição

O sistema permite manipular o nível de acesso do usuário alterando o valor do campo role dentro da requisição.

Impacto:
- acesso administrativo não autorizado
- manipulação de dados da aplicação
- comprometimento da integridade do sistema
- possibilidade de escalada de ataques adicionais

Classificação de risco

Alto

VULNERABILIDADES	SEVERIDADE
Enumeração de Diretórios	Média
Falha de controle de acesso	Alta

7. Recomendações

Para mitigar as vulnerabilidades identificadas recomenda-se:

- Implementar controle de acesso no lado do servidor
- Validar e assinar tokens de autenticação
- Utilizar mecanismos seguros de autenticação como **JWT com assinatura criptográfica**
- Implementar **controle de sessão seguro**
- Restringir acesso a diretórios administrativos
- Implementar **Web Application Firewall (WAF)**
- Realizar testes de segurança periódicos na aplicação

8. Conclusão

O teste de intrusão realizado demonstrou que a aplicação apresenta vulnerabilidades relacionadas à enumeração de diretórios e controle inadequado de autorização.

A exploração dessas falhas permitiu a elevação indevida de privilégios e acesso à interface administrativa da aplicação.

Esse tipo de vulnerabilidade representa risco significativo para a segurança do sistema, pois permite que um atacante obtenha acesso não autorizado a funcionalidades restritas.

A implementação das recomendações apresentadas neste relatório é fundamental para reduzir a superfície de ataque e melhorar a postura de segurança da aplicação.